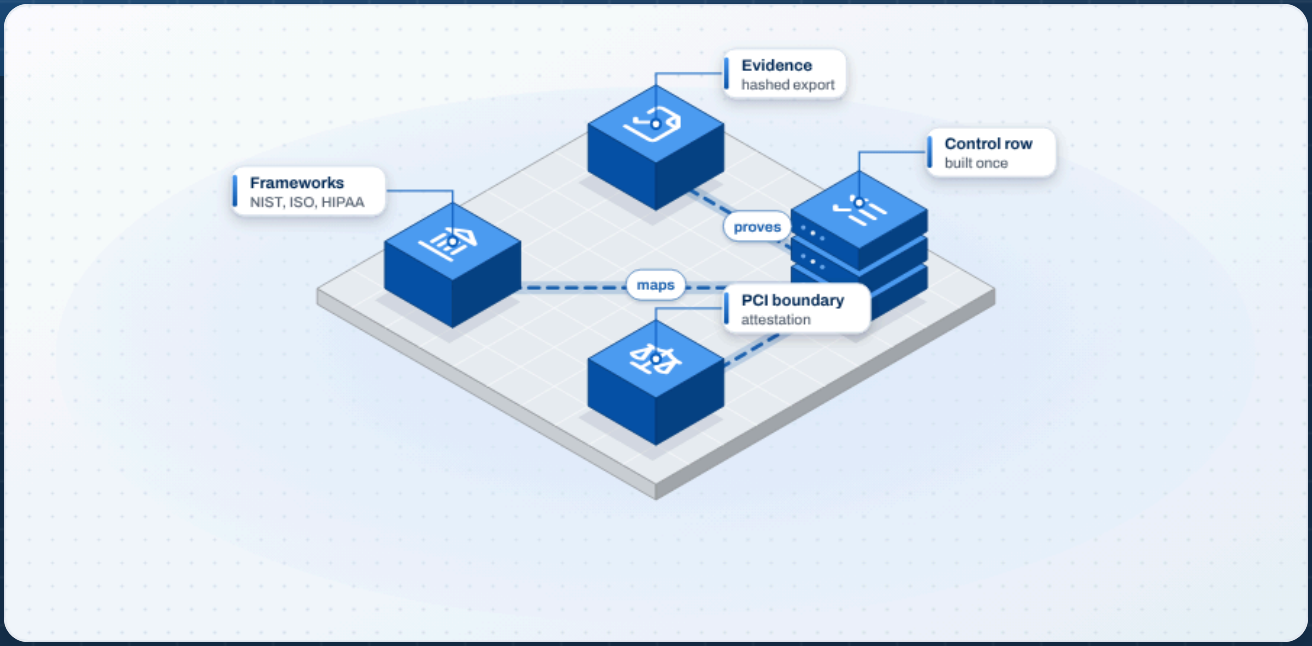
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-AZ-108

Mapping One Build to Many Compliance Frameworks

One control matrix and crosswalk across NIST CSF 2.0, NIST SP 800-53 R5, ISO/IEC 27001:2022, the HIPAA Security Rule and a PCI DSS boundary attestation, every row backed by hashed evidence.

GRC · NIST · ISO 27001



DOCUMENT ID	SOP-AZ-108
VERSION	1.1
EFFECTIVE	October 2026
AUDIENCE	Compliance analysts, auditors, client approvers
AUTHOR	Richmond Dieujuste, Principal Consultant

Rich Dieu IT Solutions LLC · richdieu.com

Sanitized reference edition · client identifiers removed

Contents

1. Concepts You Need First 2

2. Access, Prerequisites and Planning 3

2.1 Level of access required 3

2.2 Prerequisites checklist 3

3. Procedure in the Azure Portal 4

4. Template · Compliance Export and Crosswalk 7

5. Verification and Troubleshooting 8

5.1 Verify 8

5.2 Troubleshooting 8

6. Summary, Glossary and Review 9

6.1 Chapter summary 9

6.2 Glossary 9

6.3 Framework references 9

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Export policy and Defender compliance per framework as evidence.
- Write each built control once and map it across five frameworks.
- Write a PCI DSS boundary attestation that says plainly what is and is not in scope.

CHAPTER 1

Concepts You Need First

Auditors for different frameworks ask different questions about the same thing. If each framework gets its own evidence, the work multiplies and the answers drift apart. Writing each control once and mapping it across keeps one story and one set of evidence.

KEY CONCEPT · ONE RECEIPT, MANY EXPENSE REPORTS

A single receipt can support expense claims in several departments. The control is the purchase, the evidence file is the receipt, and each framework column is a department that files it.

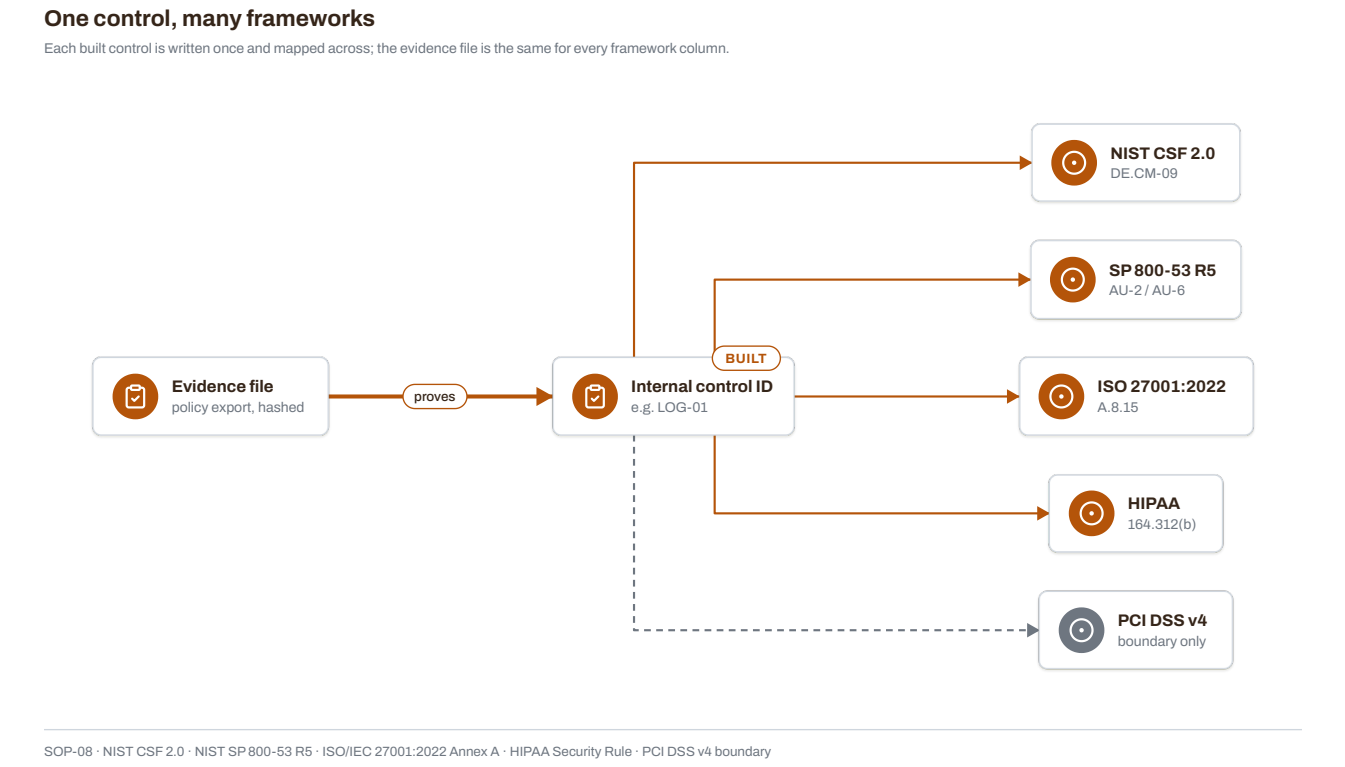


Figure 1. One built control, one evidence file, mapped to each framework column.

Framework	Granularity	Source of the mapping
NIST CSF 2.0	Outcomes (for example DE.CM-09)	Framework text
NIST SP 800-53 R5	Controls (AU-2)	Azure initiative groups
ISO/IEC 27001:2022	Annex A controls (A.8.15)	Azure initiative groups
HIPAA Security Rule	Safeguards (164.312(b))	HITRUST/HIPAA initiative
PCI DSS v4	Requirements; boundary only here	Attestation letter

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Task	Role	Notes
Export compliance	Reader and Security Reader at the root	Read only
Add standards in Defender	Security Admin on the subscription	Adds a view; changes no resource
Accept the mapping	Client approver	Signs the PCI boundary letter

CAUTION · MAP ONLY WHAT IS BUILT

Do not add rows for controls the build does not implement. A crosswalk that claims more than the evidence shows fails at the first sample.

2.2 Prerequisites checklist

- [ ] Framework initiatives assigned in Audit (SOP-AZ-101).
- [ ] Evidence manifest from the build and validation runs.
- [ ] Risk register current.

CHAPTER 3

Procedure in the Azure Portal

NOTE · HOW THESE SCREENS WERE CAPTURED

Screens in this chapter were captured read-only from a live engagement tenant. Client, product and people names, tenant, subscription and object IDs, email addresses and public IPs are replaced (`org`, `app`, `Contoso`, `00000000-…`, `203.0.113.10`). Compliance figures and unrelated rows are blurred. Portal labels move over time; the setting names are what matter.

STEP 1 Export policy compliance per initiative

1. **Policy › Compliance**; set the scope to the product root and select each framework initiative.
2. Use **Export to CSV**, or run `SOP-08-compliance-export.ps1` to export every initiative with its control groups.

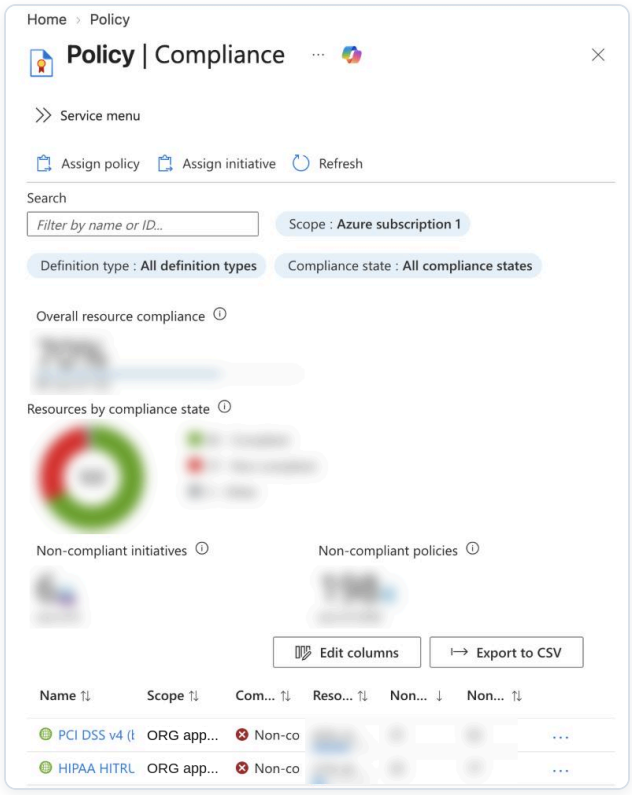


Figure 2. Policy compliance view. Figures blurred; the export behind them is the evidence.

STEP 2 Add the standards in Defender for Cloud

1. **Defender for Cloud › Regulatory compliance › Manage compliance standards**; select the subscription.
2. Add NIST SP 800-53 R5, ISO 27001, HIPAA HITRUST and PCI DSS v4; use **Download report** for each.

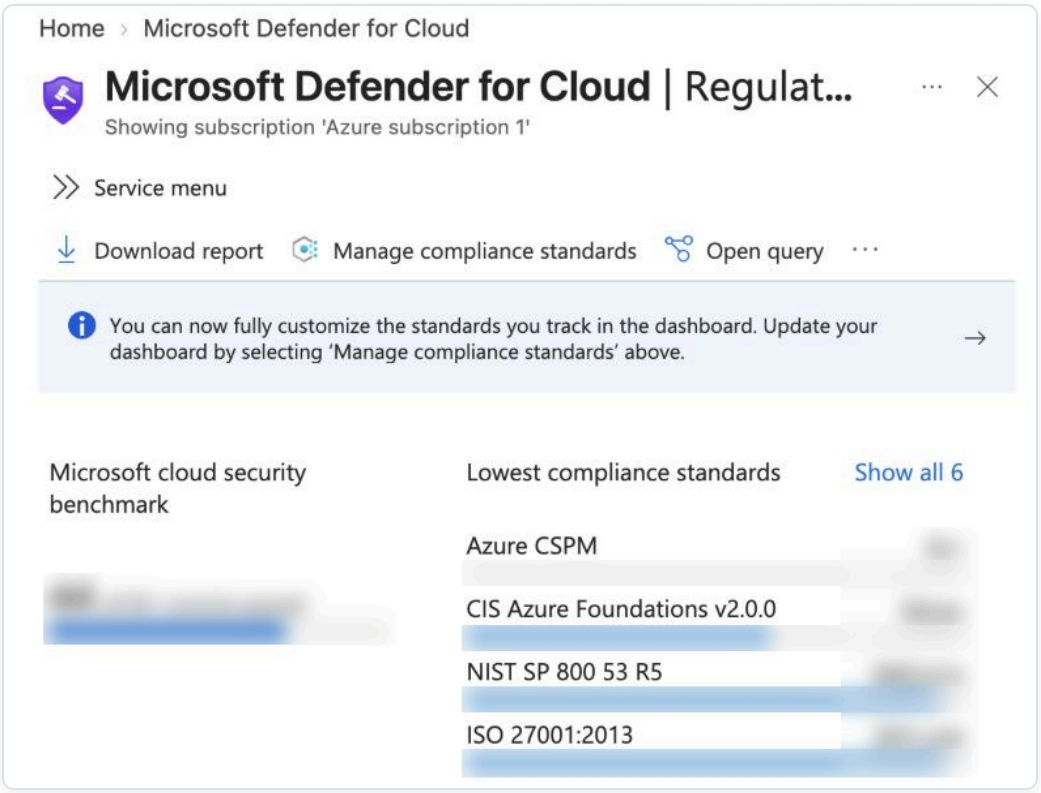


Figure 3. Regulatory compliance dashboard with the added standards. Scores blurred.

STEP 3 Write and map the control rows

1. In `SOP-08-crosswalk.template.csv` write one row per built control, with the Azure implementation and the evidence file.
2. Fill the five framework columns; use the initiative group names first, then check each against the framework text.

STEP 4 Write the PCI boundary attestation

1. State that card data is handled by the payment processor and is not stored, processed or transmitted by the tenant.

2. List the controls that keep it that way (hosted payment page or redirect, no card fields, limited egress).
3. Say plainly this is a boundary statement, not a PCI assessment.

> **WHY IT MATTERS · SCOPE IS A CONTROL**
>
> A clear boundary keeps the tenant out of PCI scope. Any change that lets card data touch the platform reopens it.

STEP 5 Package the evidence

1. Hash every export into one manifest and reference its version from the crosswalk.
2. Move every non-compliant row to the risk register, not into a footnote.

CHAPTER 4

Template · Compliance Export and Crosswalk

SOP-08-COMPLIANCE-EXPORT.PS1 · COMPLIANCE EXPORT · READ ONLY POWERSHELL

```powershell
<#  SOP-08 template: export policy compliance per framework initiative, for the crosswalk (read-only). #>
param([string]$RootMg = '<org>-<product>', [string]$Out = './compliance-export')
New-Item -ItemType Directory -Force $Out | Out-Null
$sum = Get-AzPolicyStateSummary -ManagementGroupName $RootMg
$sum.PolicyAssignments | Select-Object @{n='Assignment';e={($_.PolicyAssignmentId -split '/')[-1]}},
   @{n='NonCompliantResources';e={$_.Results.NonCompliantResources}}, @{n='NonCompliantPolicies';e=
{$_.Results.NonCompliantPolicies}} |
   Export-Csv "$Out/01-summary-by-initiative.csv" -NoTypeInformation

# Per-control rows: initiative group (control ID) -> policy -> state, for the NIST / ISO / HIPAA / PCI matrix
foreach ($a in 'nist-800-53-r5','iso-27001','hipaa-hitrust','pci-dss','cis-azure-foundations') {
  Get-AzPolicyState -ManagementGroupName $RootMg -Filter "PolicyAssignmentName eq '$a'" -Top 5000 |
    Select-Object @{n='Control';e={$_.PolicyDefinitionGroupNames -join ';'}}, PolicyDefinitionName,
ComplianceState,
                  @{n='Resource';e={($_.ResourceId -split '/')[-1]}} |
    Export-Csv "$Out/02-$a.csv" -NoTypeInformation
}
Get-ChildItem $Out | Get-FileHash -Algorithm SHA256 | Select-Object Hash, @{n='File';e={Split-Path $_.Path -
Leaf}} |
  Export-Csv "$Out/MANIFEST.csv" -NoTypeInformation
```

SOP-08-CROSSWALK.TEMPLATE.CSV · CROSSWALK ROWS · SAMPLE CSV

```csv
Control ID (internal),Control statement,NIST CSF 2.0,NIST SP 800-53 R5,ISO/IEC 27001:2022 Annex A,HIPAA Security Rule,PCI DSS v4 (boundary),Azure implementation,Evidence file,Status
IAM-01,Privileged roles granted to groups not users,PR.AA-05,AC-2 / AC-6,A.5.15 / A.8.2,164.308(a)(4),7.2.1,sg-az-* groups at product root,01-role-assignments-root.csv,Built
LOG-01,Activity log streamed to central workspace,DE.CM-09,AU-2 / AU-6,A.8.15,164.312(b),10.2.1,activity-to-law diagnostic setting,diag-settings.json,Built
LOG-02,Log archive immutable for retention period,PR.DS-01,AU-9,A.8.15,164.312(c)(1),10.5.1,WORM policy on archive containers,archive-immutability.json,Built (unlocked)
NET-01,No public IPs on network interfaces,PR.IR-01,SC-7,A.8.20,164.312(e)(1),1.3.1,deny-nic-public-ip policy,policy-compliance.csv,Built
KV-01,Secrets held in a vault read by workload identity only,PR.DS-01,SC-12 / IA-5,A.8.24,164.312(a)(2)(iv),3.6.1,Key Vault Secrets User on VM identity,kv-roles.csv,Built
BAK-01,Backups geo-redundant to paired region,PR.DS-11,CP-9,A.8.13,164.308(a)(7)(ii)(A),N/A,RSV GRS + cross-region restore,rsv-config.json,Built
```

CHAPTER 5

Verification and Troubleshooting

5.1 Verify

- ☐ Every crosswalk row names an evidence file in the manifest.
- ☐ Non-compliant counts in the export match the risk register.
- ☐ The PCI letter names the processor boundary and is signed.

5.2 Troubleshooting

Symptom	Likely cause and fix
Initiative shows no control groups	Older initiative version. Reassign the current built-in version.
Defender and Policy numbers differ	Different scopes or evaluation times. Export both at the same scope on the same day.
Auditor rejects a mapping	The control is mapped by name only. Add the evidence file and the exact setting it proves.

CHAPTER 6

Summary, Glossary and Review

6.1 Chapter summary

- Write each control once and prove it once.
- Map across frameworks from the evidence, never beyond it.
- PCI is a boundary statement here, signed by the client.

Check your understanding

1. Why map controls across frameworks instead of collecting evidence per framework?
2. What makes a crosswalk row acceptable to an auditor?
3. What would bring the tenant into PCI scope?

6.2 Glossary

Crosswalk	A table mapping one control to equivalents in several frameworks.
Boundary attestation	Signed statement of what is in and out of a framework's scope.
Initiative group	The framework control ID a policy is filed under inside an initiative.

6.3 Framework references

Framework	Controls
NIST CSF 2.0	GV.OC, GV.PO
NIST SP 800-53 R5	CA-2, CA-7, PL-2
ISO/IEC 27001:2022	6.1.3, 9.2
HIPAA Security Rule	164.308(a)(1)(ii)(A), 164.308(a)(8)
PCI DSS v4	12.5.2 (scope)